Cheatsheet AZ-104 — 05 · Storage access: keys, SAS, stored access policies and identity for Azure Files

1. The four ways to authorize

Method	What it is	Scope	Revoke	Signal
Shared Key (access keys)	Two 512-bit keys with **full access** to the whole account (all services and data)	Everything	Regenerate the key	"full access", "connection string", "mount with account key"
SAS (shared access signature)	Token in the URL with permissions, resources, time window, IP and protocol	Whatever the token says	Depends on the type (section 3)	"temporary access", "specific container", "partner without an account"
Microsoft Entra ID (data RBAC)	Roles with DataActions on blob, queue, table or Files	Per role and scope (account, container)	Remove the assignment	"most secure", "identity-based", "no keys in code"
Anonymous access	Container with Blob or Container level, if the account allows it	Public read	Change the level / disable on the account	"publicly readable images on a website"

Golden rule of the exam: when asked for "the most secure" or "least privilege" → **Entra ID** (managed identity for apps, user delegation SAS for sharing); keys and key-signed SAS only if the wording requires them.

2. Access keys

- Two keys (**key1 / key2**) to rotate without interruption: switch the apps to key2, regenerate key1, and vice versa. Regenerating a key **invalidates every SAS signed with it** (account and service SAS). A **rotation reminder** can be set (e.g. 90 days) and **Key Vault** can manage and rotate the keys for you.
- Who can see them: requires the `Microsoft.Storage/storageAccounts/listKeys/action` action → Owner, Contributor, Storage Account Contributor, **Storage Account Key Operator Service Role** (list and regenerate only). **Not Reader** (and a ReadOnly lock blocks it too).
- **"Allow storage account key access" = Disabled** → keys and key-signed SAS are blocked; only Entra ID and user delegation SAS work. Azure Files over SMB with a key stops mounting. Azure Policy can enforce this setting. Apps using a connection string fail with 403.
- Connection string = `DefaultEndpointsProtocol=https;AccountName=st1;AccountKey=...` → equivalent to handing over the key.

3. SAS: three types

	Account SAS	Service SAS	User delegation SAS
Signed with	Account key	Account key	**Entra ID credentials** (user delegation key)
Scope	One or several **services** (blob, file, queue, table) and service-level operations (create containers, properties)	**One** resource of **one** service: container, blob, share, file, queue, table	Blob (container or blob; also Data Lake) and, recently, queue, table and Files
Stored access policy	No	**Yes** (up to **5** per container / share / queue / table)	No
Duration	Whatever you set (expiration policy recommended)	Whatever you set	Maximum **7 days**
Revoke	Regenerate the key	Delete or edit the **stored access policy**; if ad hoc, regenerate the key	Revoke the user delegation key or remove the user's role
Permission to create it	Having the key	Having the key	Role with `generateUserDelegationKey` (e.g. **Storage Blob Delegator** or Storage Blob Data Contributor)
Signal	"access to multiple services", "create containers"	"share one blob / container", "revoke without regenerating keys" → + policy	"most secure", "no account key"

Parameter	Meaning
`sv`	Service version
`ss`	Services (account SAS): **b**lob, **f**ile, **q**ueue, **t**able
`srt`	Resource types (account SAS): **s**ervice, **c**ontainer, **o**bject
`sr`	Resource (service SAS): b = blob, c = container, s = share, f = file, d = directory
`sp`	Permissions: **r**ead, **w**rite, **d**elete, **l**ist, **a**dd, **c**reate, **u**pdate, **p**rocess, **t**ags, **x** delete versions...
`st` / `se`	Start / **expiry** (UTC, ISO 8601 format)
`sip`	Allowed IP or range
`spr`	Protocol: `https` (recommended) or `https,http`
`si`	**Stored access policy** identifier
`sig`	HMAC signature

- **Stored access policy:** defined on the container (or share, queue, table) with permissions, start and end; the service SAS that reference it **inherit** those limits. Changing the expiry or deleting the policy revokes all associated SAS at once **without regenerating keys**. Account SAS and user delegation SAS cannot use it.

- A SAS **cannot be audited or counted** (it is generated on the client). Best practices: HTTPS, short expiry, start 15 min in the past (clock skew), least privilege, **SAS expiration policy** on the account (warns if someone creates a longer SAS), revocation plan.
- "SAS stopped working" → the key was regenerated, it expired, the client clock is off, IP outside `sip`, HTTP with `spr=https`, or key access was disabled.

4. Entra ID and data roles

Service	Roles	Notes
Blob	**Storage Blob Data Owner** (everything + Data Lake ACLs) · **Data Contributor** (read, write, delete) · **Data Reader** · **Storage Blob Delegator** (create user delegation key)	Scope: account, container; ABAC conditions possible
Queue	Storage Queue Data Contributor · Reader · **Message Processor** (read and delete) · **Message Sender** (add)	For Functions / apps with MI
Table	Storage Table Data Contributor · Reader	—
Files (SMB)	**Storage File Data SMB Share Reader** · **Contributor** · **Elevated Contributor** (modifies NTFS ACLs)	**Share**-level permission; inside, the Windows ACLs rule
Files (REST / portal)	**Storage File Data Privileged Contributor / Reader**	Bypass the ACLs; to operate from the portal, PowerShell or AzCopy with Entra ID

- **Owner / Contributor have no data access** with Entra ID: the portal shows "You do not have permissions" when opening a container with Entra authentication; switch to "Access key" or add Storage Blob Data Reader. The **"Default to Microsoft Entra authorization in the Azure portal"** toggle sets the default method.
- For an **app or VM** → managed identity + data role (never keys in code). For a **user** → data role on just the right container.

5. Anonymous blob access

- Two levels: the **account** must have "Allow Blob anonymous access" = Enabled (new accounts come with it **Disabled**) and the **container** a level: **Private** (default), **Blob** (read blobs if you know the URL, no listing) or **Container** (read and list). "Public website images, no listing" → Blob. For security, Azure Policy can forbid anonymous access.

6. Identity for Azure Files (SMB)

Identity source	Requirements	Who it is for
On-premises AD DS	Join the storage account to the domain (computer object or service account with `Join-AzStorageAccount`), users **synchronized** to Entra ID, clients with line of sight to the **DC**	File server migration; AD DS-joined machines
Microsoft Entra Domain Services	Enable on the account; the managed domain issues the Kerberos tickets	Lift-and-shift without your own DCs; VMs joined to Entra DS
Microsoft Entra Kerberos	**Hybrid** users (synchronized from AD DS); **Entra joined or hybrid joined** clients; no DC line of sight needed to mount (needed to configure ACLs)	Remote work, Windows 365 / AVD, no VPN
Account key	Nothing, but it is **superuser**: ignores the ACLs	Initial mount to set ACLs with `icacls`, scripts; not recommended for users

- Two permission levels: **share** (Storage File Data SMB Share * RBAC role or a **default permission** for all authenticated users) and **directory / file** (regular NTFS ACLs with icacls or Explorer, after mounting with the key).
- Network: SMB uses port **445** with SMB 3.x encryption; many ISPs block it → mounting from on-prem requires **VPN / ExpressRoute + private endpoint**, or caching with **Azure File Sync**. **NFS 4.1** (Premium only) does not use identities: network control only (VNet / private endpoint); optional encryption in transit with TLS (AZNFS client) and its own "Require Encryption in Transit for NFS" setting.
- Mounting: Windows `net use Z: \\st1.file.core.windows.net\share1 /user:Azure\st1 <key>` (or the portal's "Connect" script); Linux `mount -t cifs //st1.file.core.windows.net/share1 /mnt/share1 -o username=st1,password=<key>,serverino`. With identity, a plain `net use` without credentials from a joined machine is enough.

7. Commands that show up

Task	PowerShell (Az.Storage)	Azure CLI
Regenerate key	`New-AzStorageAccountKey -ResourceGroupName RG1 -Name st1 -KeyName key1`	`az storage account keys renew -n st1 -g RG1 --key primary`
Disable keys	`Set-AzStorageAccount -ResourceGroupName RG1 -Name st1 -AllowSharedKeyAccess $false`	`az storage account update -n st1 --allow-shared-key-access false`
Account SAS	`New-AzStorageAccountSASToken -Service Blob,File -ResourceType Service,Container,Object -Permission "rl" -ExpiryTime (Get-Date).AddDays(7) -Protocol HttpsOnly -Context $ctx`	`az storage account generate-sas --account-name st1 --services bf --resource-types sco --permissions rl --expiry 2026-12-31T00:00Z --https-only`
Service SAS	`New-AzStorageContainerSASToken -Name c1 -Permission rl -ExpiryTime ... -Context $ctx` · `New-AzStorageBlobSASToken -Container c1 -Blob f.txt -Permission r ...` · with policy: `-Policy p1`	`az storage container generate-sas -n c1 --permissions rl --expiry ... --account-name st1` · `az storage blob generate-sas` · with policy: `--policy-name p1`
User delegation SAS	`$ctx = New-AzStorageContext -StorageAccountName st1 -UseConnectedAccount` → `New-AzStorageContainerSASToken ... -Context $ctx` (generates a user delegation SAS)	`az storage container generate-sas -n c1 --permissions r --expiry ... --auth-mode login --as-user`
Stored access policy	`New-AzStorageContainerStoredAccessPolicy -Container c1 -Policy p1 -Permission rl -ExpiryTime ...` · `Set-AzStorageContainerStoredAccessPolicy` · `Remove-...`	`az storage container policy create -c c1 -n p1 --permissions rl --expiry ...` · `update` · `delete`

Task	PowerShell (Az.Storage)	Azure CLI
Data role	`New-AzRoleAssignment -SignInName ana@contoso.com -RoleDefinitionName "Storage Blob Data Reader" -Scope <account or container id>`	`az role assignment create --assignee ana@contoso.com --role "Storage Blob Data Reader" --scope <id>`
Anonymous access	`Set-AzStorageAccount ... -AllowBlobPublicAccess $true` · `Set-AzStorageContainerAcl -Name c1 -Permission Blob`	`az storage account update --allow-blob-public-access true` · `az storage container set-permission -n c1 --public-access blob`
Files with AD DS	`Join-AzStorageAccount -ResourceGroupName RG1 -StorageAccountName st1 -DomainAccountType ComputerAccount`	Entra Kerberos: `az storage account update -n st1 --enable-files-aadkerb true --domain-name contoso.com --domain-guid <guid>`

8. Decision tree

```
What does the wording ask for?
├─ App in Azure accesses blobs without secrets ..... Managed identity + Storage Blob Data Contributor
├─ User views blobs in the portal with their account ..... Storage Blob Data Reader (Owner is not enough)
├─ Share a blob with an external party for a few days ..... Service SAS (user delegation SAS if "secure")
├─ Be able to revoke without regenerating keys ..... Service SAS + stored access policy
├─ Access to several services or create containers ..... Account SAS
├─ The most secure SAS, no key ..... User delegation SAS (max. 7 days)
├─ Forbid the use of keys and key-signed SAS ..... Allow storage account key access = Disabled
├─ Rotate keys without interruption ..... Alternate key1 / key2 (or Key Vault)
├─ Public images for a website ..... Account with anonymous access + Blob-level container
├─ SMB share with AD permissions for domain machines ..... Join to AD DS + SMB Share roles + NTFS ACLs
├─ SMB share for Entra joined machines without VPN or DC ..... Entra Kerberos
├─ SMB share without your own DCs (lift and shift) ..... Entra Domain Services
├─ Users cannot mount from the office ..... Port 445 blocked → VPN/ER + private endpoint or File Sync
└─ NFS ..... Premium + VNet / private endpoint (no identity)
```

9. Signals → answer

Wording	Answer
"most secure way for the app to access the storage account"	Managed identity + data role
"Owner cannot browse the container in the portal"	Missing Storage Blob Data Reader (or use the key)
"generate a SAS that can be revoked without regenerating keys"	Service SAS + stored access policy
"SAS valid for 7 days, no storage key, Microsoft Entra"	User delegation SAS
"allow listing blobs in the container for a SAS"	`l` (list) permission in `sp`
"SAS must only work over HTTPS from the office IP"	`spr=https` + `sip`
"SAS works on one blob but fails to create containers"	It is a service SAS: an account SAS with `srt` = s,c is needed
"after regenerating key1 the application fails"	Its SAS / connection strings used key1 → rotate to key2 first
"prevent the use of shared keys"	Allow storage account key access = Disabled (and Policy to audit it)
"images must be publicly readable but not listable"	Container public access = Blob
"anonymous access option is greyed out"	The account has "Allow Blob anonymous access" set to Disabled
"file share with NTFS permissions for domain users"	AD DS identity + Storage File Data SMB Share Contributor + icacls
"users must access the share from Entra joined devices over the internet"	Entra Kerberos
"mount fails with error 53 / 67 from on-premises"	Port 445 blocked
"set NTFS ACLs on the share"	Mount with the **key** (superuser) or the Elevated Contributor role
"copy files to the share with AzCopy from the portal/REST using identity"	Storage File Data Privileged Contributor
"Storage Account Key Operator Service Role"	List and regenerate keys only (least privilege for rotation)

10. Mistakes to avoid

1. Handing over the account key (or the connection string) when temporary or scoped access is requested: that is a SAS.
2. Believing an ad hoc key-signed SAS can be revoked without regenerating the key.
3. Attaching a stored access policy to an account SAS or a user delegation SAS: service SAS only.
4. Requesting a 30-day user delegation SAS: the maximum is 7.
5. Thinking Owner or Contributor read blobs with Entra ID: **data** roles are needed.
6. Forgetting that regenerating a key breaks the SAS signed with it and the apps using a connection string.
7. Setting anonymous access on the container without enabling it on the account first.
8. Choosing Entra Domain Services when users and machines are already in AD DS (and vice versa), or Entra Kerberos for **cloud-only** users (it needs hybrid identities).
9. Trying to mount SMB from home without VPN: 445 is usually blocked.